

Risk Register

OSCORP / SIMULATED NIST CSF 2.0 ASSESSMENT

Risk ID	Risk domain	Likelihood	Impact	Current score	Rating	Priority	Treatment	Recommended action	Roadmap	CSF 2.0 outcomes
R-02	Identity & Privileged Access	4	4	16	High	P1	Mitigate	MFA, unique admin accounts, access reviews	Year 1	PR.AA-01, PR.AA-03, PR.AA-05
R-04	Security Monitoring & Detection	4	4	16	High	P1	Mitigate	Critical log collection, triage, escalation	Year 1	PR.PS-04, DE.CM-01, DE.CM-09, DE.AE-03, DE.AE-08
R-05	Incident Response	4	4	16	High	P1	Mitigate	Approve IR plan, severity criteria, playbooks	Year 1	ID.IM-04, RS.MA-01, RS.MA-03, RS.MA-04, RS.AN-07
R-03	Vulnerability Management	3	4	12	High	P2	Mitigate	Authenticated scanning, SLAs, verification	Year 1–2	ID.RA-01, ID.RA-05, ID.RA-06
R-07	Data Protection & Classification	3	4	12	High	P2	Mitigate	Data discovery/classification, then DLP	Year 1–2	ID.AM-07, PR.DS-01, PR.DS-02, PR.DS-10
R-06	Third-Party Cybersecurity Risk	3	4	12	High	P2	Mitigate	Critical supplier inventory, due diligence	Year 1–2	GV.SC-01, GV.SC-04, GV.SC-05, GV.SC-06, GV.SC-07, GV.SC-08
R-01	Governance & Risk Management	3	3	9	Moderate	P3	Mitigate	Risk owners, appetite, policies, reporting	Year 1–3	GV.RM-02, GV.RM-06, GV.RR-02, GV.PO-01, ID.AM-05

Risk Matrix

OSCORP / SIMULATED NIST CSF 2.0 ASSESSMENT

Impact \ Likelihood	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5
Score	Rating				
1-4	Low				
5-9	Moderate				
10-16	High				
17-25	Critical				

Matrix values are LxI.
Project-defined thresholds; not
prescribed by NIST.

Remediation Plan

OSCORP / SIMULATED NIST CSF 2.0 ASSESSMENT

Risk ID	Priority	Proposed action	Target horizon	Suggested accountable role	Status	Evidence to validate	Dependencies / notes
R-02	P1	Require MFA and unique privileged accounts	Year 1	IT / IAM owner	Proposed	MFA policy, access logs, privileged-account inventory	Start with privileged and remote access
R-04	P1	Collect critical identity, endpoint, cloud, network logs; define triage	Year 1	Security operations owner	Proposed	Log source list, alert procedures, detection test	Broader SIEM expansion in Year 2
R-05	P1	Approve IR plan, incident roles, escalation criteria and playbooks	Year 1	Security lead	Proposed	Approved plan, playbooks, exercise results	Tabletop exercises in Year 2
R-03	P2	Schedule authenticated scans, SLAs and rescan verification	Year 1	Vulnerability owner	Proposed	Tenable schedules, remediation tickets, rescan evidence	Risk-based prioritization
R-07	P2	Discover and classify sensitive information	Year 1	Data owner	Proposed	Data inventory, classification standard	Enterprise DLP expansion Year 2
R-06	P2	Identify and review critical SaaS suppliers	Year 1	Procurement / risk owner	Proposed	Vendor inventory, diligence records	Prioritize Horizon Labs
R-01	P3	Define risk ownership, risk appetite and reporting	Year 1–3	Executive sponsor	Proposed	Approved policy, risk register, management minutes	Enables other remediation efforts

Three-Year Roadmap

OSCORP / SIMULATED NIST CSF 2.0 ASSESSMENT

Year	Objective	Planned initiatives	Success evidence (proposed)
Year 1	Reduce immediate exposure	MFA; privileged-account hygiene; critical log triage; IR plan; vulnerability SLAs; initial classification; risk owners; critical suppliers	Approved policies, configured controls, scanning and log records
Year 2	Develop operational capability	SIEM expansion; PAM maturity; vulnerability verification; DLP; vendor oversight; IR tabletop exercises	Detection tests, PAM review, DLP pilot, exercise report
Year 3	Optimize and reassess	Detection tuning; control effectiveness reviews; governance reporting; supplier reassessment; lessons learned	Trend metrics, validation results, refreshed risk register

Methodology

OSCORP / SIMULATED NIST CSF 2.0 ASSESSMENT

Item	Definition
Assessment type	Targeted, simulated NIST CSF 2.0-aligned portfolio exercise
Current risk	Likelihood (1-5) × Impact (1-5), taking scenario existing controls into account
Severity bands	1-4 Low; 5-9 Moderate; 10-16 High; 17-25 Critical
Priority logic	Separate from score; considers business impact, exposure, feasibility, dependencies and expected risk reduction
Treatment	Mitigate (proposed) for all seven risk scenarios
Mapping	Selected CSF 2.0 outcomes; analyst interpretation, not proof of compliance
Limitations	No independent testing, no approved real-world owners, costs, or implementation evidence